

Panduan Integrasi Single Sign-On (SSO) Menggunakan Hawi (Yii2), Doreh (Next.js), dan Teqic (Yii3)

Panduan ini ditujukan bagi pemula untuk memahami dan mengimplementasikan Single Sign-On (SSO) menggunakan protokol OAuth2/OIDC. Kita akan menghubungkan aplikasi **Hawi (SSO Provider)** dengan dua aplikasi client, yaitu **Doreh (Next.js)** dan **Teqic-Yii3 (Yii3)**.

Konsep Utama (Decoupled Roles)

Dalam arsitektur ini:

1. **SSO Hawi** hanya bertanggung jawab untuk memeriksa **apakah user tersebut valid** (Verifikasi Email & Password).
2. **Doreh & Teqic** tetap bertanggung jawab menentukan **role & izin (permissions) lokal** user tersebut (misal: Operator di Doreh, Admin di Teqic).
3. **Identifier Utama:** Kita menggunakan **Email** (atau **kdg** / Kode Data Guru) sebagai kunci pemetaan antar aplikasi.

Langkah 1: Daftarkan Client di SSO Hawi

Agar aplikasi Hawi mengenali Doreh dan Teqic, kita harus mendaftarkan mereka ke tabel **oauth_clients** di database **hawi**.

Jalankan perintah SQL berikut di database **hawi** Anda:

```
-- 1. Daftarkan Doreh (Next.js) sebagai Client
INSERT INTO `oauth_clients` (
  `client_id`,
  `client_secret`,
  `name`,
  `redirect_uri`,
  `is_active`,
  `created_at`,
  `updated_at`,
  `allowed_scopes`,
  `grant_types`
) VALUES (
  'doreh-client',
  -- Hash password menggunakan bcrypt (misalnya untuk string: 'doreh-secret-123')
  '$2y$13$j3eXgR09wLJ5zB8sQ9wKbe6D7yH2s1l.4hEaQv0p9zKyU8xF8mD7y',
  'Aplikasi Doreh',
  'http://doreh.local/api/auth/callback',
  1,
  UNIX_TIMESTAMP(),
  UNIX_TIMESTAMP(),
```

```

    'openid profile email',
    'authorization_code'
);

-- 2. Daftarkan Teqic-Yii3 sebagai Client
INSERT INTO `oauth_clients` (
    `client_id`,
    `client_secret`,
    `name`,
    `redirect_uri`,
    `is_active`,
    `created_at`,
    `updated_at`,
    `allowed_scopes`,
    `grant_types`
) VALUES (
    'teqic-client',
    -- Hash password menggunakan bcrypt (misalnya untuk string: 'teqic-secret-123')
    '$2y$13$X1y8uW7hR9kWbe7zP9sQKe1E2yH3s1l.5hEaQv0p8zKyU9xF9mD8z',
    'Aplikasi Teqic',
    'http://teqic-yii3.local/auth/callback',
    1,
    UNIX_TIMESTAMP(),
    UNIX_TIMESTAMP(),
    'openid profile email',
    'authorization_code'
);

```

[!NOTE] `client_secret` di database disimpan dalam bentuk hash bcrypt. Saat melakukan konfigurasi di aplikasi client (Doreh/Teqic), Anda akan memasukkan string aslinya (`doreh-secret-123` / `teqic-secret-123`).

Langkah 2: Integrasi pada Client 1 - Doreh (Next.js)

Karena Doreh menggunakan Next.js dengan JWT berbasis cookie (`lib/auth.ts`), kita dapat membuat rute login baru yang mengarahkan user ke SSO Hawi.

1. Konfigurasi Environment (`.env`)

Tambahkan variabel berikut ke dalam file `/var/www/doreh/.env`:

```

SSO_CLIENT_ID="doreh-client"
SSO_CLIENT_SECRET="doreh-secret-123"
SSO_AUTHORIZATION_URL="http://hawi.local/oauth/authorize"
SSO_TOKEN_URL="http://hawi.local/api/v1/oauth/token"
SSO_USERINFO_URL="http://hawi.local/api/v1/oauth/userinfo"
NEXT_PUBLIC_SSO_LOGOUT_URL="http://hawi.local/site/logout"

```

2. Alur Login / Autentikasi

Buat file handler callback di Next.js (misalnya `app/api/auth/callback/route.ts` jika menggunakan App Router) untuk menangani response dari SSO:

```
import { NextResponse } from 'next/server';
import { createSession } from '@lib/auth';
import { prisma } from '@lib/prisma';

export async function GET(request: Request) {
  const { searchParams } = new URL(request.url);
  const code = searchParams.get('code');

  if (!code) {
    return NextResponse.redirect(new URL('/login?error=no_code', request.url));
  }

  try {
    // 1. Tukar auth code dengan access token ke Hawi
    const tokenResponse = await fetch(process.env.SSO_TOKEN_URL!, {
      method: 'POST',
      headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
      body: new URLSearchParams({
        grant_type: 'authorization_code',
        code: code,
        client_id: process.env.SSO_CLIENT_ID!,
        client_secret: process.env.SSO_CLIENT_SECRET!,
        redirect_uri: 'http://doreh.local/api/auth/callback',
      })),
    );

    const tokenData = await tokenResponse.json();
    if (tokenData.error) {
      return NextResponse.redirect(new URL(`/login?error=${tokenData.error_description}`, request.url));
    }

    // 2. Ambil informasi profil user menggunakan access token
    const userinfoResponse = await fetch(process.env.SSO_USERINFO_URL!, {
      headers: { 'Authorization': `Bearer ${tokenData.access_token}` }
    });

    const ssoUser = await userinfoResponse.json();

    // 3. Cocokkan email dari SSO dengan database lokal Doreh
    let localUser = await prisma.authUser.findUnique({
      where: { email: ssoUser.email }
    });
  }
}
```

```

// 4. Jika user belum ada di lokal, buat user baru secara otomatis
(optional)
if (!localUser) {
    localUser = await prisma.authUser.create({
        data: {
            email: ssoUser.email,
            username: ssoUser.username || ssoUser.email.split('@')
[0],

            nama_lengkap: ssoUser.name,
            password: '', // Kosongkan karena login via SSO
            is_active: true
        },
    });

    // Berikan default role di Doreh (misal: Operator)
    const operatorRole = await prisma.authRole.findUnique({ where:
{ name: 'Operator' } });
    if (operatorRole) {
        await prisma.authUserRole.create({
            data: { user_id: localUser.id, role_id: operatorRole.id
}
        });
    }
}

// 5. Buat session cookie lokal Doreh
await createSession(localUser.id);

// Redirect ke dashboard doreh
return NextResponse.redirect(new URL('/dashboard', request.url));

} catch (error) {
    console.error('SSO Callback error:', error);
    return NextResponse.redirect(new URL('/login?error=server_error',
request.url));
}
}

```

Langkah 3: Integrasi pada Client 2 - Teqic-Yii3 (Yii3)

Pada Teqic-Yii3, kita akan memodifikasi `AuthController.php` agar dapat mengarahkan login ke Hawi.

1. Tambahkan Konfigurasi Ke `/config/common/params.php`

Tambahkan konfigurasi client di parameter Yii3:

```

'sso' => [
    'clientId' => 'teqic-client',
    'clientSecret' => 'teqic-secret-123',
    'authorizeUrl' => 'http://hawi.local/oauth/authorize',

```

```

        'tokenUrl' => 'http://hawi.local/api/v1/oauth/token',
        'userinfoUrl' => 'http://hawi.local/api/v1/oauth/userinfo',
        'redirectUri' => 'http://teqic-yii3.local/auth/callback',
    ],

```

2. Modifikasi `AuthController.php`

Tambahkan action baru untuk mengarahkan login ke SSO dan menangani callback:

```

// Tambahkan action loginSSO untuk me-redirect ke SSO
public function loginSSO(): ResponseInterface
{
    $params = $this->params->get('sso');
    $url = $params['authorizeUrl'] . '?' . http_build_query([
        'response_type' => 'code',
        'client_id' => $params['clientId'],
        'redirect_uri' => $params['redirectUri'],
        'scope' => 'openid email profile',
        'state' => bin2hex(random_bytes(16)), // Untuk keamanan CSRF
    ]);

    return $this->responseFactory->createResponse(302)-
>withHeader('Location', $url);
}

// Tambahkan action callback untuk menangani kembalian dari SSO
public function callback(ServerRequestInterface $request):
ResponseInterface
{
    $queryParams = $request->getQueryParams();
    $code = $queryParams['code'] ?? null;

    if ($code === null) {
        $this->flash->set('errors', 'Autentikasi SSO dibatalkan atau
gagal.');
```

```

        return $this->responseFactory->createResponse(302)
            ->withHeader('Location', $this->urlGenerator-
>generate('login'));
    }

    $params = $this->params->get('sso');

    // 1. Tukar auth code dengan access token
    $ch = curl_init($params['tokenUrl']);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
    curl_setopt($ch, CURLOPT_POST, true);
    curl_setopt($ch, CURLOPT_POSTFIELDS, http_build_query([
        'grant_type' => 'authorization_code',
        'code' => $code,
        'client_id' => $params['clientId'],
        'client_secret' => $params['clientSecret'],
    ]));

```

```

        'redirect_uri' => $params['redirectUri'],
    ]));

$response = curl_exec($ch);
curl_close($ch);
$tokenData = json_decode($response, true);

if (isset($tokenData['error'])) {
    $this->flash->set('errors', 'Gagal menukarkan token: ' .
$tokenData['error_description']);
    return $this->responseFactory->createResponse(302)
        ->withHeader('Location', $this->urlGenerator-
>generate('login'));
}

// 2. Ambil profil user menggunakan access token
$ch = curl_init($params['userinfoUrl']);
curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
curl_setopt($ch, CURLOPT_HTTPHEADER, [
    'Authorization: Bearer ' . $tokenData['access_token']
]);
$userinfoResponse = curl_exec($ch);
curl_close($ch);
$ssoUser = json_decode($userinfoResponse, true);

// 3. Cocokkan email SSO dengan tabel users lokal Teqic
$user = $this->authRepository->findByEmail($ssoUser['email']);

// 4. Jika user terdaftar, login-kan ke session local Yii3
if ($user !== null) {
    $this->userSession->login($user); // user akan mendapatkan role
    local 'Admin'
    $this->flash->set('success', 'Berhasil masuk menggunakan SSO!');
    return $this->responseFactory->createResponse(302)
        ->withHeader('Location', $this->urlGenerator-
>generate('home'));
} else {
    $this->flash->set('errors', 'Email SSO Anda tidak terdaftar sebagai
Admin di aplikasi ini.');
```



Langkah 4: Cara Switch Aplikasi dengan Mudah

Untuk mempermudah perpindahan antar aplikasi, Anda cukup menambahkan tombol navigasi atau dropdown menu di bagian atas panel navigasi masing-masing aplikasi:

Di Doreh (Next.js):

```
<a href="http://teqic-yii3.local/auth/login-sso" className="btn btn-  
primary">  
  Buka Teqic (Admin)  
</a>
```

Di Teqic-Yii3 (PHP):

```
<a href="http://doreh.local/api/auth/login-sso" class="btn btn-warning">  
  Buka Doreh (Operator)  
</a>
```

Mengapa ini sangat cepat?

Saat user mengklik tautan di atas, aplikasi tujuan akan me-redirect browser user ke SSO `hawi.local`. Karena browser user **sudah menyimpan session cookie aktif dari Hawi** (karena login pertama), aplikasi Hawi akan langsung mengenali user dan langsung me-redirect kembali ke callback client tanpa meminta user mengetik username/password lagi. Proses ini terjadi kurang dari 1 detik!

Langkah 5: Penanganan Logout (Single Sign-Out)

Jika user keluar (logout) dari salah satu aplikasi, sebaiknya mereka juga keluar dari SSO agar sesi aman.

1. **Logout Lokal:** Hapus session lokal aplikasi client (Next.js / Yii3).
2. **Redirect ke SSO Logout:** Setelah menghapus session lokal, arahkan user ke URL logout milik Hawi:

```
http://hawi.local/site/logout
```

3. Hawi akan menghapus session SSO utama di browser user, sehingga saat user mencoba membuka aplikasi lain, mereka akan diminta login ulang.